

Tema 3 — Anexo B: OPA/Rego en Agent Gateway

Slides independientes del deck principal de Tema 3 — después del Anexo A (Agent Identity) y de 3.4.1/3.4.2 (PEP/PDP, OPA/Rego)

El PDP con Rego en GCP: lo que la plataforma te da, y lo que hay que construir

- Teoría 3.4.1: **PEP** intercepta y aplica, **PDP** decide
- ¿El PDP con Rego de la clase (atado al SPIFFE ID como atributo de sujeto) corre sobre GCP, conectado a los agentes de los Anexos 0/A?
- Respuesta corta: sí, pero **no nativo** — hay que construirlo

El PEP sí está: **Agent Gateway**

- Componente nativo y gestionado: **Agent Gateway**
- Intercepta cada llamada del agente hacia herramientas, servidores MCP o APIs de GCP
- Valida la identidad SPIFFE (SVID de Agent Identity — mTLS terminado ahí, DPoP hacia adelante, ver Anexo A)
- Aplica la decisión que le llega — exactamente el rol del PEP de 3.4.1

El PDP también está, pero no habla Rego

GCP sí tiene un PDP nativo — motor propio y cerrado, tres mecanismos:

1. **Model Armor** — sanitización semántica (prompt injection, tool output)
2. **IAM + Context-Aware Access** — acceso según identidad y contexto
3. **Semantic Governance Policies** — JSON/YAML, qué herramientas/MCP puede invocar el agente

Ninguno usa Rego. La doc de Agent Gateway no menciona OPA ni Rego en ningún lado.

¿GCP no usa OPA/Rego? Sí, pero no en la capa agéntica

- **GKE: Gatekeeper** = admission webhook que el API server consulta antes de aceptar un recurso; evalúa contra `ConstraintTemplates` en **Rego** — mismo lenguaje del Fragmento de Código 2
- **CI/CD** (Terraform/Cloud Build): OPA contra el `plan` antes de aprovisionar, rechaza infra que viole política
- Práctica madura y extendida — el estándar existe en infraestructura, no (aún) en la capa agéntica

¿Y Cedar?

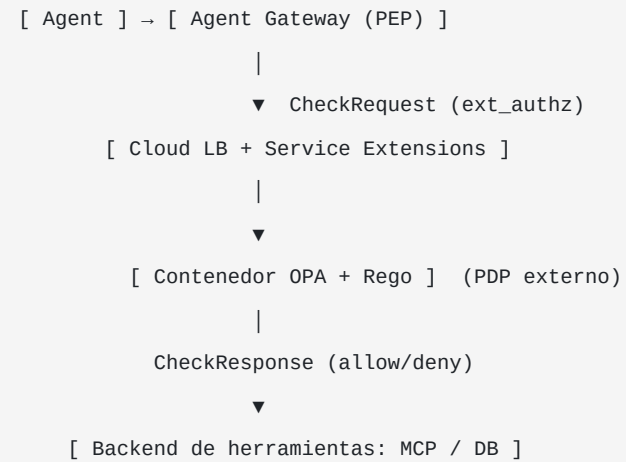
- Lenguaje de policy-as-code de **AWS** (Amazon Verified Permissions, Bedrock AgentCore)
- **No tiene soporte nativo en GCP** — no es bloqueo activo, simplemente no es su stack
- Si aparece en material sobre agentes, es casi siempre contexto AWS

Cómo se construye el PDP con Rego para Agent Gateway

Patrón documentado por Google — tres piezas:

1. **PDP**: contenedor OPA evaluando Rego (`default allow = false` , ABAC sobre `input.subject.spiffe_id`)
2. **Intercepción**: Cloud LB + Service Extensions, protocolo `ext_authz` — API gRPC de Envoy (`envoy.service.auth.v3`), la misma que implementa el **OPA-Envoy plugin** oficial
3. **Identidad real**: el LB debe propagar el SPIFFE ID (mTLS/JWT) hasta el callout — no viene gratis solo por tener Agent Identity habilitado

Mecánica del callout: CheckRequest / CheckResponse



Estado de disponibilidad — cita textual de la doc oficial

"the External Authorization or ext_authz protocol is also supported in Preview"

"In Preview, [...] you can configure authorization extensions separately for request authorization policies and content authorization policies"

- Sujeto a "**Pre-GA Offerings Terms**": soporte limitado, disponible *"as is"*
- `ext_proc` (route/traffic extensions) sí es **GA** hace tiempo — pero la vía para conectar OPA (`ext_authz`) **no lo es**

Del lado positivo, con la misma precisión

- **Model Armor sobre Agent Gateway:** confirmado **GA** en doc oficial
- **Agent Runtime** (`reasoningEngines` , ADK/BYOC): capacidad madura, GA desde antes del rebrand
- Cualquier fuente que diga "Service Extensions = GA" sin distinguir `ext_authz` está siendo imprecisa

Arquitectura recomendada si querés evitar piezas en Preview

1. **Agente:** Agent Runtime (GA), o Cloud Run/GKE (GA hace años)
2. **PDP:** contenedor OPA + Rego — open source, sin dependencias de preview
3. **Intercepción:** Service Extensions + `ext_authz` (mostrar como Preview, con la cita textual) • sidecar/reverse-proxy manual con Envoy + OPA-Envoy plugin (100% GA)
4. **Identidad** (opcional): Agent Identity (usable en demo, madurez formal no confirmada) • Service Accounts + Workload Identity Federation (100% GA)

Cierre: el contraste que vale la pena que se lleven

- **Autenticación** (SPIFFE vía Agent Identity): "prender y configurar" — la plataforma hace el trabajo criptográfico pesado (Anexo A)
- **Autorización de grano fino con Rego** (Tema 3): sigue siendo trabajo de ingeniería que hay que construir y operar
- GCP da el punto de intercepción (Service Extensions, aún Preview) — no el motor de políticas
- Incluso en una plataforma madura, la teoría del Tema 3 (PEP, PDP, ABAC con Rego) es trabajo real de arquitectura, no algo resuelto por defecto

Fuentes

- [Callouts overview | Service Extensions | Google Cloud Documentation](#)
- [Configure an authorization extension | Service Extensions | Google Cloud Documentation](#)
- [OPA-Envoy Plugin | Open Policy Agent](#)
- [Agent Gateway overview | Gemini Enterprise Agent Platform | Google Cloud Documentation](#)
- [Model Armor release notes | Google Cloud Documentation](#)